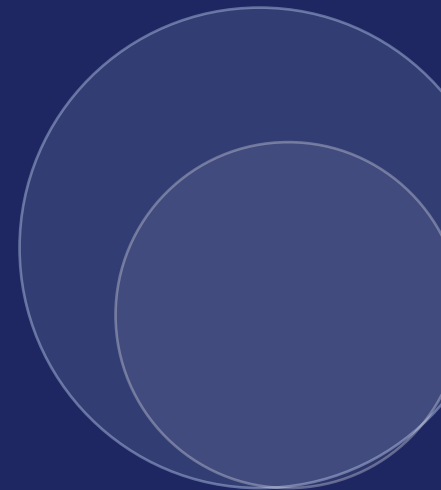


CASE STUDY – EXAM

Computer Forensics and the Law

The TechMed S.r.l. Case

BEC Fraud · Malware · Personal Data Breach · GDPR Art. 33-34 · Art. 615-ter / 640-ter Italian Criminal Code
Politecnico di Torino · A.Y. 2025/2026



The Case: TechMed S.r.l.

Who is TechMed?

- >> Via Roma 45, 10121 Torino, Italy
- >> 85 employees | EUR 12M annual turnover
- >> Patient management software for clinics and hospitals

Personal data processed:

- 85 employees (HR records incl. occupational health data)
- ~450 client contacts at hospitals/clinics
- ~3,200 patients in cloud testing database
(names, dates of birth, medical record numbers, diagnostic codes)

Key Personnel

CEO: Dott. Andrea Colombo
IT Manager: Ing. Marco Benedetti
Finance Manager: Dott.ssa Elena Ferri (auth. up to EUR 100k)
DPO: Avv. Laura Rossi

IT Infrastructure

- Windows AD · Exchange 2019 on-premise
- Cloud DB: CloudItalia S.r.l., Milan
- VPN · Fortinet FortiGate 60F firewall
- Windows Defender (antivirus)

Incident Timeline

● Mon 15/04 08:45	Phishing email sent to Giovanni Martini (from: hr.notifications@techmed-portal.com)
● Mon 15/04 08:50	Martini opens attachment 'Payroll_Form_2026.docx' → malware installed on workstation
● Mon 15/04 08:52	First C2 connection (185.143.223.45): 450 KB exfiltrated (credentials + employee email list)
● Mon 15/04 09:15	Second C2 connection: 12.3 MB exfiltrated (HR_Confidential shared folder)
● Mon 15/04 10:30	Finance Manager Ferri receives spoofed email from 'CEO' requesting urgent EUR 95,000 wire transfer
● Mon 15/04 11:15	Ferri authorises wire transfer to TechSolutions GmbH – Deutsche Bank (IBAN: DE89...)
● Tue 16/04 09:00	CEO returns from business trip, denies sending email → bank contacted, funds already transferred out
● Tue 16/04 10:00	IT Manager begins investigation and discovers the data exfiltration breach
● Tue 16/04 14:30	DPO (Avv. Laura Rossi) informed of the personal data breach
● Tue 16/04 15:00	Martini's workstation isolated from network (without shutdown) · Forensics Italia S.r.l. engaged
● Wed 17/04 09:00	Forensic team acquires: disk image (FTK Imager), RAM dump, firewall logs, email server logs
● Thu 18/04	Criminal complaint filed with Procura della Repubblica, Torino (Art. 615-ter, 640-ter c.p., Art. 167 D.Lgs. 196/2003)

The Attack Chain



Personal Data Breach

- 85 employees: emails, names, ID card copies, contracts (addresses, tax codes, bank account numbers)
- Possible access to patient DB (3,200 records)

- Notifiable data breach (GDPR Art. 33)
- High risk for employees (identity theft, fraud)

Financial Damage – BEC Fraud

- EUR 95,000 transferred to foreign account
- Funds already forwarded to unknown destination
- Criminal offence: Art. 640-ter Italian Criminal Code

- CEO email spoofing (a.colombo@techmed.it)
- No SPF / DKIM / DMARC on company domain

Digital Evidence Collection – Priority Order

1st**RAM Dump (volatile memory)**

Highest priority: volatile data lost on shutdown. Contains: active processes, network connections, encryption keys, in-memory malware traces. Tools: DumpIt / Magnet RAM Capture.
Hash: immediate SHA-256 post-acquisition.

2nd**Disk Image (Martini's workstation – 192.168.1.55)**

Second priority: workstation already isolated (not shut down → RAM preserved). Bit-for-bit acquisition with FTK Imager. Integrity verification: MD5 + SHA-256 on the .E01 file.
Preserve chain of custody on write-blocked media.

3rd**Firewall Logs (Fortinet FortiGate 60F)**

Third priority: data on active system but not immediately alterable. Period: 14-17 April 2026. Export in native format + copy to immutable storage.
Hash: SHA-256 for each log file.

4th**Email Server Logs (Exchange 2019)**

Fourth priority: structured data, least volatile. Collect: message tracking logs, IIS logs, full email headers. Period: 14-17 April 2026.
Hash: SHA-256 for each exported archive.

Firewall Log Analysis & Data Exfiltration

Time	From (IP)	To (C2)	Volume	Likely Content
08:52 CET, 15/04	192.168.1.55	185.143.223.45	450 KB	Credentials, 85 employee email list, system config
09:15 CET, 15/04	192.168.1.55	185.143.223.45	12.3 MB	HR_Confidential folder: 85 ID card copies + employment contracts (PDF)

Size analysis: 450 KB consistent with structured text (credentials + email list). 12.3 MB consistent with 85 PDFs (ID cards + contracts, avg ~145 KB each).

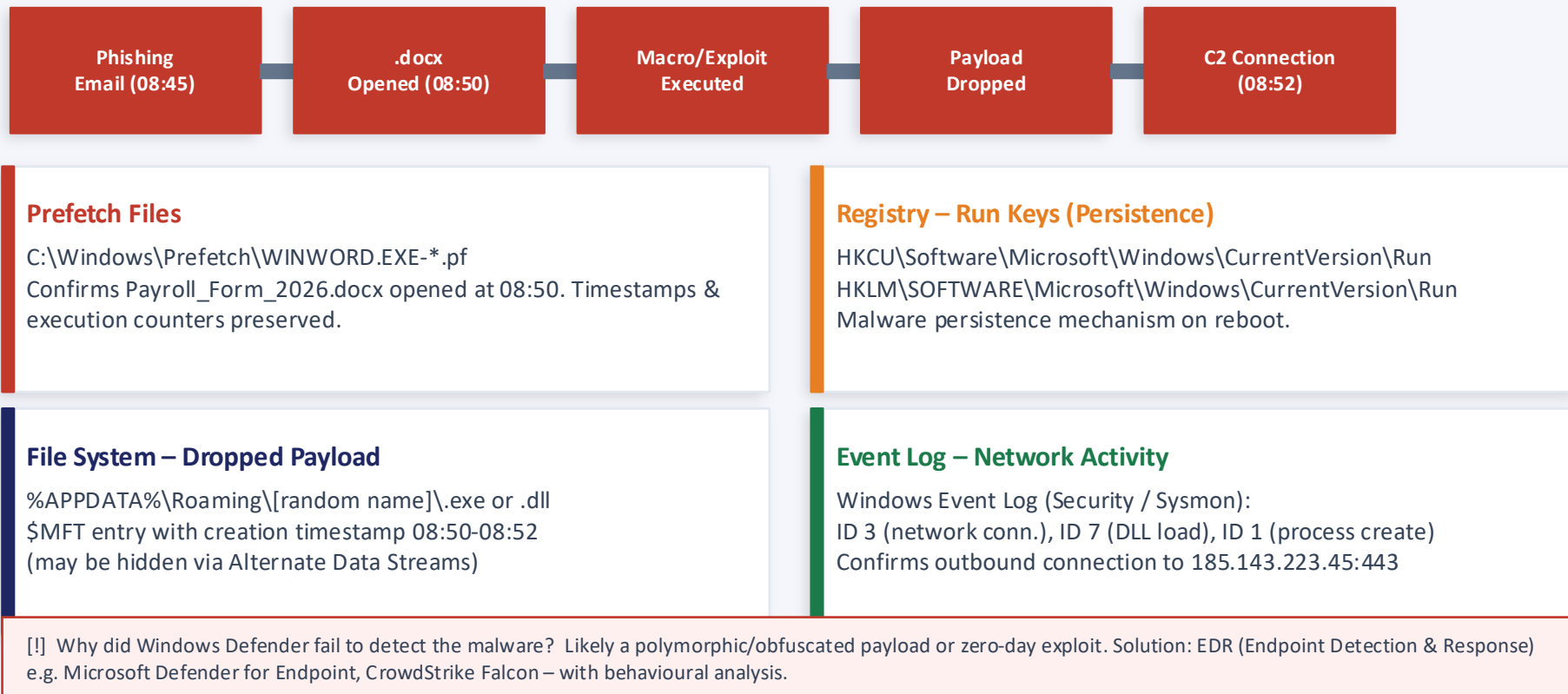
Measure 1 – DLP (Data Loss Prevention)

Monitor/block outbound data transfers to unauthorised IPs. Alert threshold: transfers > 5 MB to unknown hosts. Tools: Fortinet CASB, McAfee DLP.

Measure 2 – IDS/IPS + Threat Intelligence

Intrusion detection system with IP reputation feeds. IP 185.143.223.45 would already be flagged as a C2 server in threat intelligence databases (e.g. AlienVault OTX, Cisco Talos).

Malware – Infection Chain & Forensic Artifacts



Art. 615-ter c.p. – Unauthorised Computer Access

ELEMENT: Third-party computer system

→ TechMed's email server (protected corporate system)

ELEMENT: Access / retention against the owner's will

→ Credentials stolen from Martini used without authority

ELEMENT: Security measures in place

→ AD authentication + VPN present

ELEMENT: Specific intent (dolo specifico)

→ Targeted exfiltration of email list and HR folder

Aggravating circumstance (para. 2):

→ Breach by external actor causing damage

→ Data theft = aggravating factor (Art. 615-ter, para. 3)

Art. 640-ter c.p. – Computer Fraud

ELEMENT: Interference with a computer system

→ Spoofing of a.colombo@techmed.it email address

→ Fraudulent manipulation of email system (header forgery)

ELEMENT: Alteration / interference without authority

→ Fraudulent use of CEO's digital identity

ELEMENT: Wrongful profit / damage to another party

→ Profit: EUR 95,000 received in German account

→ Damage: TechMed deprived of the funds

Aggravating circumstance: Art. 640-ter, para. 2

→ Damage $\geq$ EUR 50,000 → increased sentence

→ Possible concurrence with Art. 494 c.p. (identity substitution)

GDPR Art. 33 – Moment of Awareness & Deadlines

Tue 16/04 10:00

IT Manager discovers the data exfiltration

Organisation's awareness

Tue 16/04 14:30

DPO (Avv. Laura Rossi) informed

Formal confirmation – but NOT the relevant moment

Thu 17/04 10:00

DEADLINE: 72 hours from awareness

Supervisory authority must be notified by this time

RISK ASSESSMENT (GDPR Art. 33) – The breached data creates a high risk to the rights and freedoms of the data subjects:

IDENTITY THEFT

ID card copies + tax codes + IBANs → realistic risk of fraudulent account opening

FINANCIAL FRAUD

Employee IBANs → risk of salary re-direction to attacker accounts

SPEAR-PHISHING

Full email list → targeted phishing attacks against all 85 employees

CONCLUSION: Notification to supervisory authority MANDATORY (Art. 33) | Communication to data subjects MANDATORY (Art. 34 – high risk)

Notification to the Supervisory Authority – GDPR Art. 33

(a) Nature of the breach

Unauthorised exfiltration of personal data following malware infection of an employee workstation. Affected: 85 employees (identification data, ID card copies, contracts with tax codes and IBANs). Possible exposure of ~3,200 patient records in testing database.

(c) Likely consequences

Identity theft, financial fraud (employee IBANs), targeted spear-phishing against all 85 employees, possible breach of medical professional secrecy (patient diagnostic data).

(b) DPO – Contact point

Avv. Laura Rossi – dpo@techmed.it
TechMed S.r.l., Via Roma 45, 10121 Torino (IT)

(d) Measures taken or proposed

Immediate workstation isolation (15:00, 16/04) · Forensic acquisition (17/04) · Reset of compromised credentials · Email server monitoring · Criminal complaint filed Torino (18/04) · EDR deployment underway · Communication to data subjects in preparation.

GDPR Art. 34 – Obligation triggered: high risk (identity theft, IBANs, health data) requires direct communication to data subjects without undue delay.

DRAFT COMMUNICATION TO EMPLOYEES

Subject: Notification of Personal Data Breach pursuant to GDPR Art. 34

Dear [employee name],

TechMed S.r.l. suffered a personal data breach on 15 April 2026. Malware installed on a company workstation enabled the exfiltration of data contained in the HR_Confidential shared folder.

Data involved: first and last name, email address, residential address, tax code (codice fiscale), copy of identity card, bank account number (IBAN) from your employment contract.

Risks: identity theft, financial fraud, targeted phishing.

Recommended actions: Monitor your bank account statements regularly, be wary of unusual emails, and report any signs of misuse of your documents. For assistance please contact the DPO: dpo@techmed.it.

TechMed S.r.l. sincerely apologises for this incident and remains at your disposal for any clarification.

Four Organisational Failures & Remedies

F1 No SPF / DKIM / DMARC

- Fact:** CEO email spoofing succeeded → Ferri had no means to verify sender authenticity
- Rule:** GDPR Art. 32 – appropriate technical measures; NIS2 Art. 21 – email security
- Remedy:** Publish SPF, DKIM and DMARC DNS records with p=reject policy within 30 days.

F2 No Emergency Payment Verification Procedure

- Fact:** Ferri executed a EUR 95k wire transfer based solely on an email, without any verbal check
- Rule:** ISO 27001 A.6.1.2 (segregation of duties); anti-BEC best practice
- Remedy:** Policy: any transfer > EUR 50k requires verbal confirmation with the requester before execution.

F3 Insufficient Antivirus (signature-based only)

- Fact:** Windows Defender failed to detect the polymorphic/zero-day malware
- Rule:** GDPR Art. 32(1)(b) – integrity and confidentiality; NIS2 Art. 21(2)(e)
- Remedy:** Deploy EDR (Endpoint Detection & Response) with behavioural analysis e.g. Microsoft Defender for Endpoint.

F4 Lack of Anti-Phishing Training

- Fact:** Martini opened attachment from suspicious domain (techmed-portal.com vs. techmed.it)
- Rule:** GDPR Art. 32(1)(b); ISO 27001 A.7.2.2; NIS2 Art. 21(2)(g) – staff training
- Remedy:** Quarterly phishing simulations + mandatory annual security awareness training for all staff.

Anti-Spoofing Email Technologies

SPF

Sender Policy Framework: the techmed.it DNS record lists all servers authorised to send email. An external server spoofing @techmed.it fails the SPF check and the message is rejected.

DKIM

DomainKeys Identified Mail: cryptographic signature in every email header. The receiving server verifies the signature against the public key published in DNS, detecting any tampering.

DMARC

Combines SPF and DKIM with a DNS-published policy. With p=reject, emails failing either check are rejected at the gateway — preventing spoofing of the visible From: address.

Payment Authorisation Policy

Any wire transfer exceeding EUR 50,000 requires direct verbal confirmation (by phone or in person) with the requester before execution, regardless of any instruction received by email.

In the absence of such confirmation, the payment must be suspended and escalated to the CEO and Finance Manager through an alternative channel.

Regulatory References

- ISO 27001: A.14.2.5 (secure system engineering)
- NIS2 Directive Art. 21: email security requirements
- DMARC RFC 7489 (IETF) – policy p=reject
- GDPR Art. 32 – appropriate technical & organisational measures

Key Takeaways

The TechMed Case – Computer Forensics and the Law

01 Digital Forensics

Chain of custody and collection order (RAM, disk, logs) are fundamental for the admissibility of evidence in criminal proceedings.

02 Criminal Law

BEC + malware satisfy Art. 615-ter and 640-ter with potential aggravating factors. International jurisdiction requires a European Investigation Order.

03 GDPR

Awareness = 16/04 at 10:00 → notification within 72h. High risk → communication to data subjects mandatory (Art. 34).

04 Organisation

SPF/DKIM/DMARC + EDR + anti-phishing training + payment policy: proportionate and legally required measures even for 85 employees.